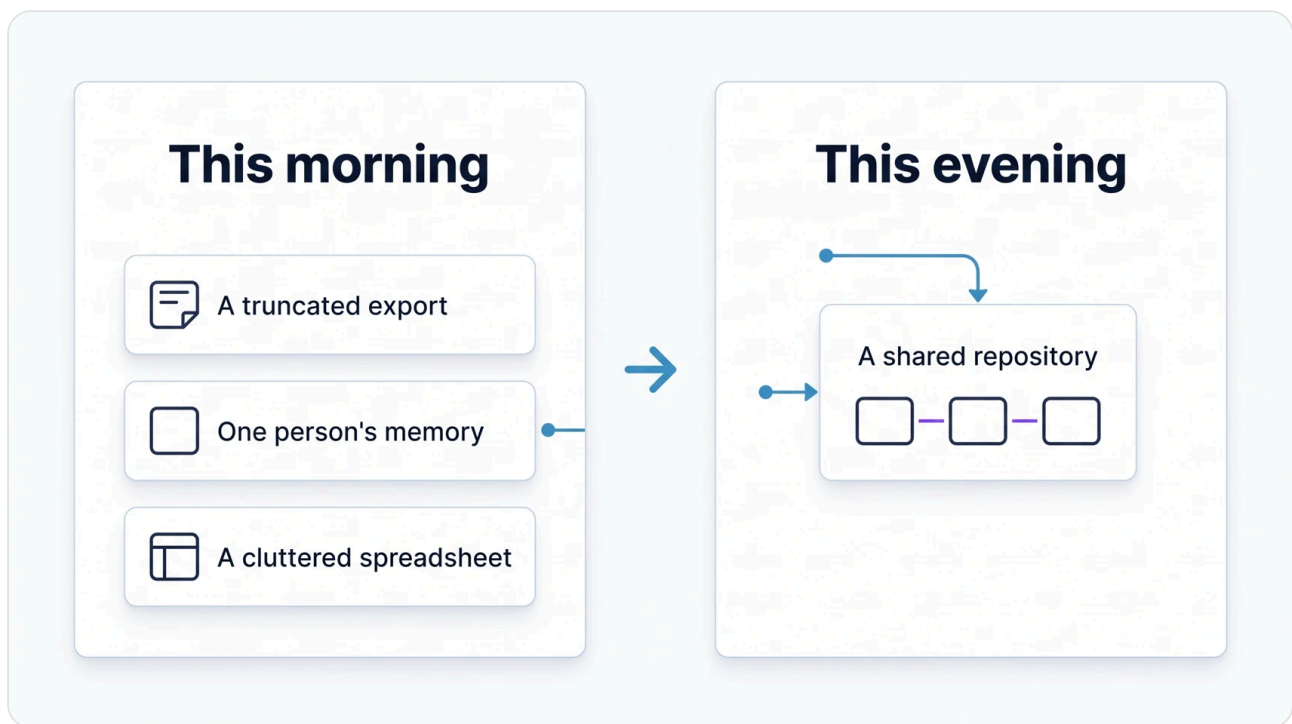


Entering the mapping into CISO Assistant

Objective: by the end of the hour, the map of the subsidiary under study exists in the tool



Three incompatible media this morning, one common repository this evening.

Session objectives

By the end of this lab, the working group's instance contains: the MERIDIAN perimeter of the subsidiary under study, created and named according to the group convention; at least three business assets entered as primary assets; their supporting assets entered and attached; the security needs filled in for each business asset; and a proof of state exported or captured. What is learned here:

- **Explain** what a GRC tool is, what it brings compared to the morning's spreadsheets, and what it will never do in the analyst's place
- **Transpose** without betraying them the tutorial's notions, business asset, supporting asset, DICT needs, into the tool's objects
- **Apply** the data entry discipline that makes the difference between a governance base and a tidy dumping ground

Prerequisites

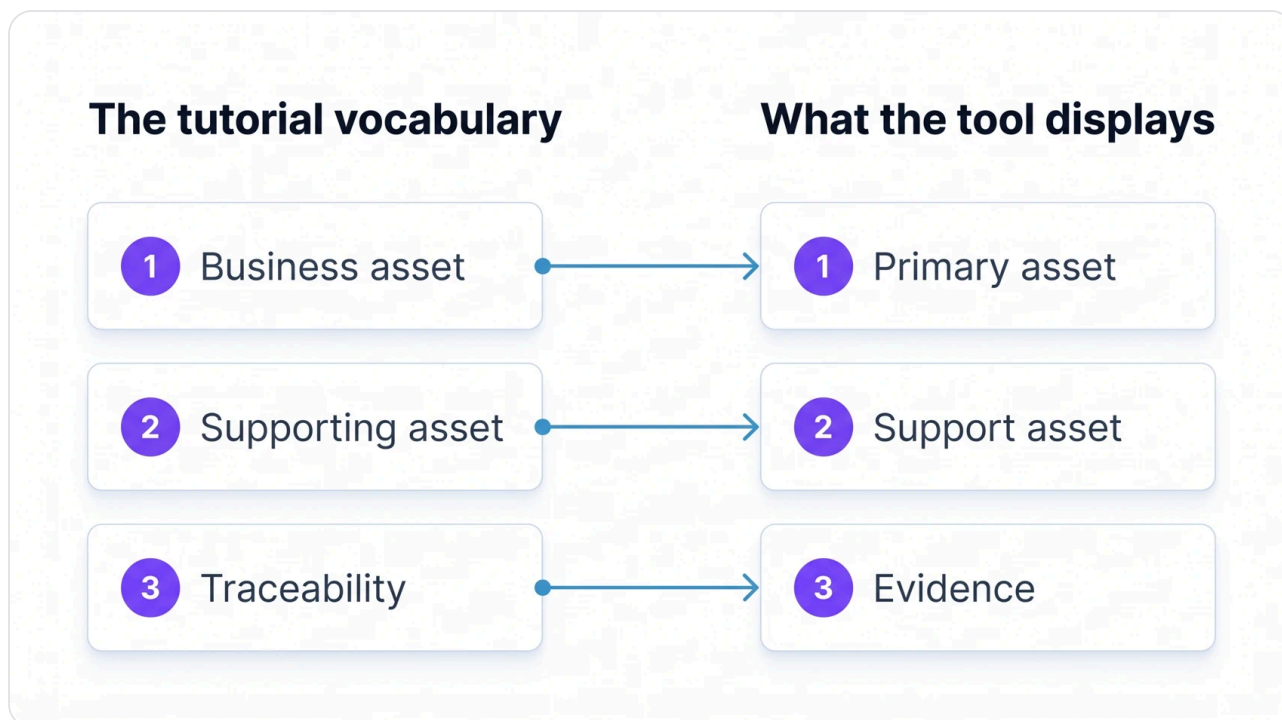
- This midday's tutorial: the tables of business assets, supporting assets and DICT ratings for the subsidiary under study. This lab creates no new content: it ENTERS what is already built; an empty tutorial table gets filled in first.
- The morning lecture: the maturity trajectory and granularity, which justify starting sober.
- Session 1's governance: each group works on its subsidiary's instance, and the inventory rule arbitrated at the CISO's briefing already applies to data entry: every object will have an owner.

The GRC tool: what it is, and why the group has one

Before entering anything, the object deserves to be understood, because "GRC tool" quickly becomes an everyday word in a CISO's life, and the group's map is not entrusted to an acronym one cannot defend.

The problem first, touched with a finger this morning: spreadsheets. Santé's mapping in a file, Logistique's in a head, the Éducation & Territoires discoveries in a third format; no common vision, no history, no way to know who changed what, and at every request from an auditor or a management team, a week of manual consolidation. A **GRC tool**, for governance, risk and compliance, is the software that centralizes these objects, assets, perimeters, requirements, assessments, in a single structured base, with links between them, owners, a history. Its mechanics rest on three promises: a common vocabulary imposed by the tool's structure, exactly the one the tutorial laid down; navigable relations, this business asset rests on these supporting assets, no longer juxtaposed lines; and a trace, who entered what and when. Its limit, to be engraved before the first click: the tool structures, it does not think. A badly phrased business asset remains badly phrased in a database; a GRC tool filled without method is a dumping ground with menus. The method is the morning; the tool is only its receptacle.

The group's tool is called CISO Assistant, a free and open-source GRC software published by intuitem, deployed for the module with one instance per working group. Two things to know about its way of ordering the world, because they match the tutorial to the letter. On the one hand, an asset there is one of two types: **primary**, matching the tutorial's business assets, or **support** (« soutien »), matching the supporting assets and attached to a parent asset. The correspondence is no accident: it is the vocabulary of the ISO 27005 and EBIOS family, seen in the tutorial, that the tool takes up. On the other hand, each asset carries **security objectives**, among which confidentiality, integrity, availability and proof; it is the tutorial's DICT, with traceability lodging there under the term « preuve » (proof). A screen label that differs slightly from this course must not stop anyone: the structure is that one, and it is what must be found.



The same object, two names: the method's, and the tool's.

Two ways to access it, as preferred. Either the instance provided by the group, at <https://<instance>.lockbay.eu>, where <instance> is the working group's: medsecure, translog, educonnect or cityadmin, suffixed -a or -b. The complete table appears in the reference dossier. Or a personal deployment of CISO Assistant: the project is open source and its documentation gives the procedure. Both ways produce the same work and the same exported proof of state, and the choice belongs to each person.

The nature of this environment is a lesson of the module as much as an instruction. Its availability is high, its integrity medium, its confidentiality low: it is not a production tool. Only the MERIDIAN case, which is fictional, is entered there. No real data, no person's name, no element from an internship or an employer. Rating a tool's confidentiality before pouring anything into it is exactly the reflex this module installs.

The golden rule of data entry, valid in any GRC tool for an entire career: never enter what has not been decided on paper. The tool records decisions; made in front of the screen, under the pressure of the mandatory field, they are almost always bad.

Step 1: create the perimeter and lay down the convention (10 minutes)

Each group creates in its instance the MERIDIAN working perimeter of its subsidiary.

1. **Create** the perimeter of the subsidiary under study, named according to the group convention: MERIDIAN-SANTE, MERIDIAN-LOGISTIQUE, MERIDIAN-EDUCATION or MERIDIAN-TERRITOIRES, in capitals and without accents, the MERIDIAN casing being the group rule and the absence of accents a precaution of interoperability.

2. **Fill in** its description in one useful sentence: the subsidiary's sector and the mission it serves, taken from the tutorial. A description is useful if someone outside the group understands what it is about without calling the author.
-

3. **Note** on the validation sheet the creation time and the author: it is the first line of the history.
-

Validation criterion: the perimeter exists, its name respects the convention, its description is useful in the sense above.

Step 2: enter the business assets (15 minutes)

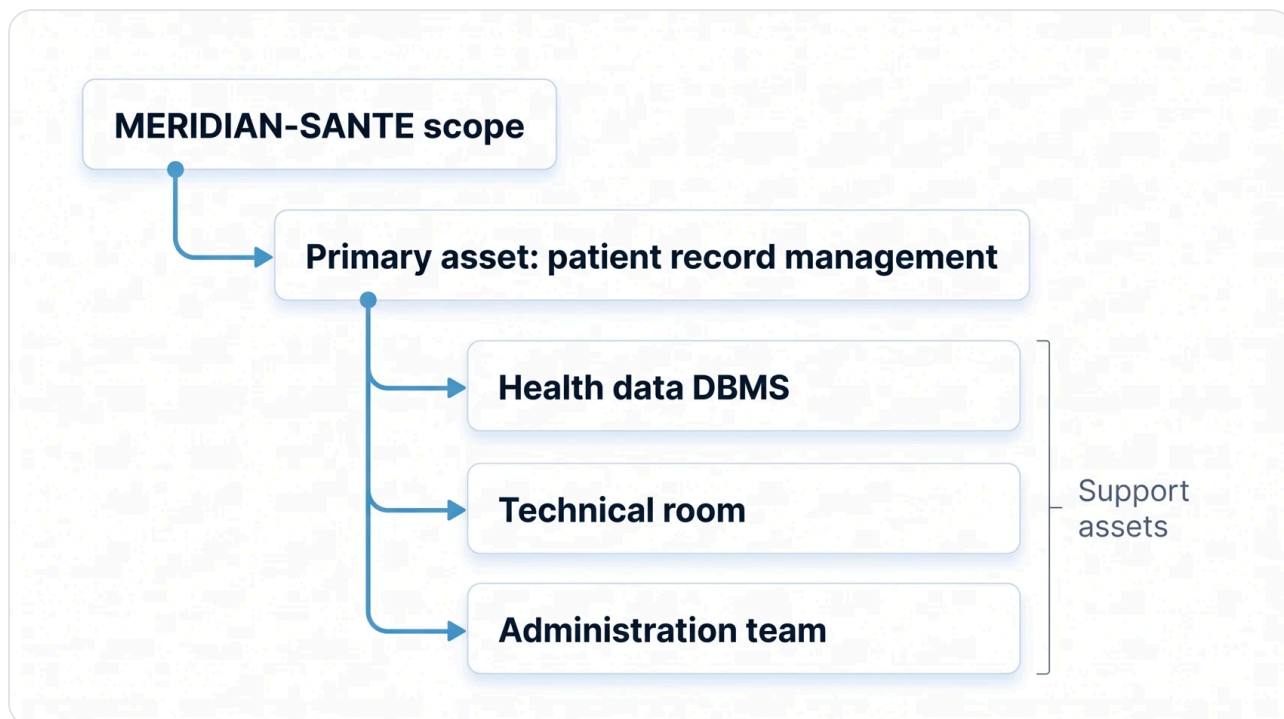
1. **Create** as primary assets the subsidiary's business assets from the tutorial, at least three, keeping their exact business phrasing: "patient record management", not "the PR Oracle database".
-
2. **Fill in** for each one a description of one to two sentences: what the subsidiary would lose if this asset were harmed, that is the best possible description of a business asset.
-
3. **Resist** the temptation to enter fifteen: the morning's trajectory commands starting with a sober, complete level 1, and the EBIOS RM guide, which returns in session 5, sets the useful order of magnitude, a handful of well-chosen business assets rather than a catalog.
-

Validation criterion: at least three primary assets, named in business language, each with a description in terms of loss.

Step 3: attach the supporting assets (15 minutes)

1. **Create** as support assets the supporting assets from the tutorial's table, and **attach** each one to the business asset or assets it carries: it is this link, not the list, that turns data entry into a mapping.
-
2. **Cover** the three natures seen in the tutorial: at least one digital supporting asset, one physical, one organizational. The organizational one, the team that administers, the provider that operates, is the one every tool in the world lets slip, because no probe detects it.
-

3. **Verify** the morning's inventory rule on each object: a named owner. An asset without an owner in the tool is exactly the ownerless server from the CISO's briefing, only tidier.



The expected shape in the tool: the link makes the map.

Validation criterion: each business asset has at least one supporting asset attached; the three natures are represented; no asset without an owner.

Step 4: fill in the security needs (10 minutes)

1. **Carry over** onto each business asset the tutorial's DICT ratings, in the asset's security objectives: availability, integrity, confidentiality, and traceability under its « preuve » (proof) label.

2. **Keep** the tutorial's relative scale, without refining it on screen: if the tool offers more levels than the rating, do not invent precision the analysis did not produce. False precision born of drop-down menus is the occupational disease of GRC tools.

3. **Indicate** in the asset's description, in one sentence, the justification of the dominant rating; whoever reads the map in six months must find the why next to the how much.

Validation criterion: each business asset carries its needs filled in, and the dominant rating is justified in one sentence.

Step 5: the inter-subsidiary running thread, and the proof of state (10 minutes)

The Santé and Logistique groups have extra stitching work, the other groups follow it as active observers: the "emergency supply" business asset, walked through in tutorial exercise 3, belongs to Santé but rests on Logistique supporting assets, handheld scanners, inventory management system, API, dedicated VLAN, inspection firewall.

1. **Enter** this business asset on the Santé side and its supporting assets where they live, documenting the inter-subsidiary dependency in the descriptions: each instance being a single subsidiary's, it is the DESCRIPTION that carries the link between the two today, and this limitation is a lesson in itself, to be noted for the debrief.
-

2. **Export or capture** the final state of the instance, the list of assets and their links: it is the end-of-lab proof, the one the grid below verifies, and the starting point of the next lab, which will extract the group's Top 5 from it.
-

Answer keys and assessment criteria

Answer key: the expected traps, and why it is these

Three traps come back every year on this exercise; here they are with their antidote. The first: technical business assets, "WMS server" entered as a primary asset. The antidote is the tutorial's test, who weeps over its disappearance; if the answer is "the IT department", the object goes down one floor and gets attached to a real business asset. The second: the catalog-map, fifteen business assets rated "very important" everywhere. The antidote is twofold, the sober volume of step 2 and the relative position of step 4; a level 1 map that ranks is worth more than an exhaustive inventory that ranks nothing. The third: the missing organizational supporting asset, because no menu explicitly asks for it. The antidote is to start from the tutorial's paper table, where it appears, and not from the screen, which will not suggest it; Logistique's operations team, sole holder of the warehouses' knowledge in the morning's finding, is the canonical example of what the map must from now on make visible.

Self-assessment grid

CRITERION	VALIDATED IF
Perimeter	Created, named according to the MERIDIAN-SUBSIDIARY convention, useful description
Business assets	At least three primary assets in business language, descriptions in terms of loss
Supporting assets	Attached to their business assets, the three natures represented, one owner per asset
Security needs	DICT carried over without invented precision, dominant rating justified in one sentence
Running thread	The Santé-Logistique dependency documented, its tooling limitation noted for the debrief
Proof of state	Export or capture completed, ready to serve as input to the next lab

What this hour has really produced

The measure takes ten seconds: in the morning, knowledge of the group's information system lived in a truncated export, one man's memory and an embarrassed spreadsheet. It now lives in a shared tool, structured in the profession's official vocabulary, linked, dated, attributed. It is still only a level 1 of maturity, and that is exactly what the guide's trajectory prescribes for a first milestone. The next lab builds on it immediately: extracting from this base the group's Top 5 critical assets, and writing it where decisions are made, in the strategy note.